

Live Red-Team Completion Report

Session-Bound Agent Identity Profile

Status as of 2026-06-21

This report contains AI-generated draft text and remains under human verification.

Treat conclusions as provisional until referenced checks are independently confirmed.

Copyright (c) 2026 ToppoMicroServices OÜ

Source: `docs/live-red-team-report.md`

Normative profile source: `docs/SSOT.md`

Live Red-Team Completion Report

Copyright (c) 2026 ToppoMicroServices OÜ

Verification notice: this report contains AI-generated draft text and remains under human verification. Treat its conclusions as provisional until the referenced checks are independently confirmed.

This report summarizes the completed live-style red-team work for the session-bound agent identity profile. The normative profile source is `docs/SSOT.md`.

Status

Current mainline coverage is synchronized with `docs/SSOT.md` draft v0.4 as of 2026-06-21. The profile now includes direct-Agent JWT/JWS and CWT/COSE verification, dependency-free live-style relay and HTTP/2 reuse harnesses, deterministic malformed-token corpus tests, a deterministic JWT acceptance invariant matrix, and local Gateway Route Assertion validation.

Earlier branch-scoped implementation and verification completed on 2026-06-13. Additional local regressions were run on 2026-06-16 for attestation-binder absence and Manager/Agent key-role separation.

- Implementation verification commit: `2ebd52694d88bef6d0a5e3fae2593ec9bfd8647`
- GitHub Actions **Security Red Team** run #3 on that commit: success
- GitHub Actions **CI** run #3 on that commit: success

The gateway-routed profile is separate from direct-Agent mode because its trust model is different: the gateway is the TLS endpoint and must authenticate the gateway-to-Agent route before the intended Agent can be treated as accepted. The Gateway Route Assertion claim map, final-Agent holder-of-key proof rules, local policy gate, and JWT/CWT route-assertion adapters are now defined. Runtime client/server wiring and a full gateway-routed network harness remain separate work.

The current evaluation is not a proof of the full security claim. It is a v0.4 evaluation built from focused local checks, negative vectors, unit-level tests, dependency-free live-style harnesses, and deterministic invariant checks. Claims such as "this grant is accepted only for this session" still need real 0-RTT transport, gRPC pooling, full gateway network, randomized fuzz/property, and hardware-backed attestation coverage before they should be treated as broadly validated.

Verification Evidence

GitHub Actions:

Workflow	Run	Result	Notes
Security Red Team	27466465706	Success	Dedicated red-team workflow for AGTP/aTLS security packages
CI	27466465697	Success	lint, Build, all Go test matrix jobs, and coverage upload passed

Local verification:

```
/opt/homebrew/bin/go test -v -race -count=1 ./pkg/agtp ./pkg/atls/identitypolicy ./pkg/clients
↪ ./pkg/atls/internal_transport
git diff --check
```

Both checks passed for the referenced implementation commit.

Focused local regression run on 2026-06-16:

```
env GOCACHE=/tmp/go-build-cocos go test -count=1 ./pkg/agtp ./pkg/atls/identitypolicy ./pkg/clients
```

All three packages passed.

Focused LRTT14 regression run on 2026-06-21:

```
go test -v -count=1 ./pkg/agtp -run
↳ TestVerifySessionIdentityJWTLiveRedTeamRejectsTLSResumptionReplayAndPreBinding
```

The test passed and did not skip the TLS resumption path.

v0.4 release-preparation checks on 2026-06-21:

```
go test -count=1 ./pkg/agtp ./pkg/atls/identitypolicy ./pkg/clients ./pkg/agtp/gatewayroute
git diff --check
pdftinfo docs/SSOT.pdf
```

All checks passed. docs/SSOT.pdf rendered as a 24-page PDF.

Claim-to-Evaluation Matrix

Claim or attack class	Current evidence	Remaining evaluation
Real network relay attack	Real TLS exporter binding is exercised in an in-memory TLS 1.3 harness. TestVerifySessionIdentityJWTLiveRedTeamRejectsNetworkRelayAcrossEndpoints runs two live loopback TLS endpoints and rejects a binding relayed from endpoint A to endpoint B.	Extend LRTT12 with an active forwarding proxy and deployment-specific TLS exporter material when the runtime server profile exists.
Borrowed attestation	Binder mismatch, missing binder, report-data mismatch, and nonce mismatch are covered in local tests.	LRTT11: generate hardware-backed evidence in a confidential-VM or equivalent environment and replay it across another session.
Token substitution and cross-JWT confusion	Covered by grant substitution and single-envelope JWT substitution tests.	Keep as regression coverage; add malformed serialization cases under fuzzing.
Same TLS connection with multiple tasks	TestVerifySessionIdentityJWTLiveRedTeamHTTP2ConnectionReuse runs task A and task B over one reused HTTP/2 TLS connection and rejects task A's binding in task B's request context.	Add gRPC service-level coverage when a profile-bearing gRPC API is fixed.
HTTP/2 or gRPC connection reuse	The HTTP/2 harness verifies connection reuse, accepted same-context bindings, and rejected cross-context bindings.	Add gRPC connection-pooling coverage and cross-Agent / cross-authority-scope cases.
TLS resumption and 0-RTT	TestVerifySessionIdentityJWTLiveRedTeamRejectsTLSResumptionReplayAndPreBinding establishes an initial TLS 1.3 session and a resumed TLS 1.3 session, derives exporter hashes from each, accepts fresh per-session binding material, rejects the initial Session Binding Statement on the resumed session, and rejects a pre-binding statement without <code>tls_exporter_sha256</code> .	Real 0-RTT early-data transport coverage remains future work because the Go standard TLS stack used by this harness does not expose a 0-RTT API.
Distributed replay race	Local goroutine race and local multi-process SETNX-style service are covered.	LRTT03b: repeat against real multi-node Redis or Valkey, including failover and timeout behavior.
Gateway route confusion	SSOT defines gateway route-assertion requirements, docs/gateway-routed-profile.md fixes the Gateway Route Assertion claim map and holder-of-key proof, pkg/agtp/gatewayroute rejects route, tenant, policy, task, target-Agent, nonce, audit-hash, replay, and missing-proof confusion, and pkg/agtp verifies JWT/JWS and CWT/COSE route-assertion wire tokens.	Add a full gateway-routed network harness when runtime client/server wiring exists.

Claim or attack class	Current evidence	Remaining evaluation
JWT/JWS parser robustness	Deterministic negative tests cover supported claim and signature paths. TestVerifySessionIdentityJWTRedTeamRejectsMalformedCorpus rejects malformed compact JWS, duplicate protected-header or payload JSON members, and unsafe control-character claims.	Add Go fuzz targets and long-running corpus jobs for Unicode, duplicate JSON keys, malformed base64url, malformed protected headers, and malformed JWS structure.
Grant, binding, session, and expected-policy invariants	TestVerifySessionIdentityJWTInvariantMatrix enumerates grant hash, request context, TLS exporter, attestation binder, audience, role-separated context, task, replay, and local-policy invariants through the same JWT acceptance gate.	Add long-running property or fuzz generation if the project wants randomized invariant exploration.

Implemented Coverage

Test	Coverage	Result
TestAGTPObservedIdentityAcceptsManagerIssuedGrantE2E	Manager-signed Identity Grant plus Agent-signed Session Binding Statement through the client hook.	Passed locally and in GitHub Actions
TestAGTPObservedIdentityRedTeamRealTLSAttestationBinding	Real TLS 1.3 exporter-derived attestation binder is accepted, while a binding borrowed from another TLS / attestation session is rejected.	Passed locally and in GitHub Actions
TestAGTPObservedIdentityAcceptsHTTPJWKSAndRejectsRevocation	HTTP-backed key lookup and revoked grant jti rejection.	Passed locally and in GitHub Actions
TestAGTPObservedIdentityRedTeamRejectsAttacks	Peer-signed grant, service/tenant/deployment diversion, borrowed leaf-key binding, and borrowed request context.	Passed locally and in GitHub Actions
TestAGTPObservedIdentityRedTeamRejectsAgentThreats	Agent/task/delegation/scope/resource/authorization red-team cases through the same client hook.	Passed locally and in GitHub Actions
TestAGTPObservedIdentityRedTeamRejectsReplay	Reuse of the same valid Session Binding Statement against the same replay cache.	Passed locally and in GitHub Actions
TestAGTPObservedIdentityRedTeamRejectsReplayRace	Concurrent reuse of the same valid Session Binding Statement through one shared replay cache.	Passed locally and in GitHub Actions
TestAGTPObservedIdentityRedTeamRejectsReplayRaceMultiProcess	Multiple local worker processes race the same valid Session Binding Statement through one HTTP SETNX-style replay service.	Passed locally and in GitHub Actions
TestAGTPObservedIdentityRedTeamRejectsKeyAndRevocationFailures	Stale JWKS, key rotation overlap, HTTP JWKS 500 and timeout, revocation-source outage, disabled Manager key, revoked grant jti , and disabled Agent binding key failures.	Passed locally and in GitHub Actions
TestAGTPObservedIdentityRedTeamRejectsAttestationBinderMismatch	Session Binding Statement with only attestation_binder_sha256 changed from the accepted attestation binder.	Passed locally and in GitHub Actions
TestAGTPObservedIdentityRedTeamRejectsMissingAttestationBinder	Accepted lower-layer attestation binder requires attestation_binder_sha256 in the Session Binding Statement.	Passed locally
Evidence-binding freshness tests	Report-data and nonce mismatches reject evidence that is not bound to the current verifier challenge and TLS exporter binding.	Passed locally; live stale hardware evidence is outside this dependency-free CI profile

Test	Coverage	Result
TestAGTPObservedIdentityRedTeamRejectsManagerKeyAsBindingKey	Manager signing key cannot be reused as the Agent confirmation or Session Binding Statement key.	Passed locally
TestAGTPObservedIdentityRedTeamRejectsGrantSubstitution	Binding statement whose <code>grant_hash</code> targets a different Manager-signed Identity Grant.	Passed locally and in GitHub Actions
TestAGTPObservedIdentityRedTeamRejectsVerifiedGrantCacheMiss	Previously accepted grant reused after the grant <code>ti</code> is revoked, with a fresh binding nonce.	Passed locally and in GitHub Actions
TestVerifySessionIdentityJWTEnvelopeRedTeamRejectsSubstitution	Single-envelope JWT/JWS rejects inner-grant substitution, outer <code>grant_hash</code> mismatch, skipped inner or outer signature verification, Agent-signed semantic claims, and missing inner grants.	Passed locally and in GitHub Actions
TestVerifySessionIdentityCWTAcceptsManagerGrantAndLocalPolicy	Manager-signed CWT/COSE Identity Grant plus Agent-signed CWT/COSE Session Binding Statement map to the same identity-policy model as JWT/JWS.	Passed locally and in GitHub Actions
TestVerifySessionIdentityCWTRedTeamRejectsCOSEProfileAttacks	CWT/COSE rejects forged grants, tampered grant signatures, wrong binding signers, grant substitution, stale bindings, local-policy mismatch, and unprotected <code>kid</code> .	Passed locally and in GitHub Actions
TestValidateResponseCachePolicyRedTeamRejectsCallerDependentPublicCache	Caller-dependent endpoint declared <code>public</code> is rejected; the harness shows the cross-Agent collision that a method/path/input-only shared cache would create.	Passed locally
TestValidateResponseCachePolicyRedTeamPartitionsPrivateCache	Caller-dependent endpoint declared <code>private</code> with <code>Agent-ID</code> and <code>Authority-Scope</code> partitioning does not leak an admin-scoped cached response to a read-only Agent.	Passed locally
TestVerifySessionIdentityJWTLiveRedTeamRejectsNetworkRelayAcrossEndpoints	Two live loopback TLS endpoints accept their own bindings and reject a binding relayed from endpoint A to endpoint B.	Passed locally
TestVerifySessionIdentityJWTLiveRedTeamHTTP2ConnectionReuse	One HTTP/2 TLS connection carries task A and task B requests; task A's binding is rejected in task B's request context, while task B's own binding is accepted.	Passed locally
TestVerifySessionIdentityJWTLiveRedTeamRejectsTLSResumptionReplayAndPreBinding	Initial and resumed TLS 1.3 sessions derive distinct exporter hashes; the old Session Binding Statement is rejected on the resumed session, fresh resumed-session binding is accepted, and a pre-binding statement without <code>tls_exporter_sha256</code> is rejected.	Passed locally
TestVerifySessionIdentityJWTRedTeamRejectsMalformedCorpus	JWT/JWS rejects malformed compact serialization, duplicate protected-header or payload JSON members, and unsafe control-character semantic claims.	Passed locally
TestVerifySessionIdentityCWTRedTeamRejectsMalformedCorpus	CWT/COSE rejects empty, truncated, malformed CBOR, and non-COSE binding bytes.	Passed locally
TestValidateAcceptsRouteAssertionWithAgentHolderProof	Gateway Route Assertion acceptance requires local route policy and a matching final-Agent holder-of-key proof.	Passed locally
TestValidateRejectsPolicyBoundDiversion	Valid gateway assertions are rejected when route, tenant, policy, task, target Agent, holder nonce, audit hash, proof freshness, or proof hash is wrong.	Passed locally
TestValidateRejectsMissingRequiredAgentHolderProof	A gateway assertion without a required final-Agent holder-of-key proof fails closed.	Passed locally

Test	Coverage	Result
TestValidateRejectsRouteAssertionReplay	Reuse of a Gateway Route Assertion nonce through the same replay cache is rejected.	Passed locally
TestVerifyGatewayRouteJWTAcceptsLocalPolicy	JWT/JWS Gateway Route Assertion adapter verifies the gateway signature and accepts only with matching local route policy, expected grant hash, gateway session-binding hash, holder proof hash, and replay cache.	Passed locally
TestVerifyGatewayRouteJWTRedTeamRejectsAttacks	JWT/JWS Gateway Route Assertion adapter rejects route diversion, grant-hash substitution, gateway-session substitution, holder-proof hash substitution, missing replay cache, and wrong gateway signing key.	Passed locally
TestVerifyGatewayRouteJWTRejectsMissingProtectedKeyIDAndReplay	JWT/JWS Gateway Route Assertion adapter rejects missing protected <code>kid</code> and replay through the route replay cache.	Passed locally
TestVerifyGatewayRouteCWTAcceptsLocalPolicy	CWT/COSE Gateway Route Assertion adapter maps canonical CBOR claims to the same route policy gate.	Passed locally
TestVerifyGatewayRouteCWTRedTeamRejectsAttacks	CWT/COSE Gateway Route Assertion adapter rejects route diversion, grant-hash substitution, gateway-session substitution, holder-proof hash substitution, unprotected COSE <code>kid</code> , and replay.	Passed locally
TestVerifySessionIdentityJWTInvariantMatrix	The JWT acceptance invariant rejects mismatched grant hash, request context, TLS exporter, attestation binder, audience, role-separated context, task, replay, and local policy.	Passed locally

LRTT Status

ID	Status	Completion evidence	Boundary
LRTT01	Completed for the dependency-free CI harness	TestAGTPObserveIdentityRedTeamRealTLSAttestationBinding covers real TLS 1.3 exporter binding, certificate material, accepted attestation payload, AGTP hook acceptance, and borrowed-session rejection	Hardware-generated confidential-VM evidence is not exercised in this local CI profile
LRTT02	Completed	TestVerifySessionIdentityCWTAcceptsManagerGrantAndLocalPolicy and TestVerifySessionIdentityCWTRedTeamRejectsCOSEProfileAttacks	Runtime client configuration remains JWT/JWS-wired unless callers use the CWT verifier directly

ID	Status	Completion evidence	Boundary
LRTT03	Completed	<code>TestAGTPObserveIdentityRedTeamRejectsReplayRaceMultiProcess</code>	Real multi-node Redis / Valkey deployment is outside the local harness
LRTT04	Completed	<code>TestAGTPObserveIdentityRedTeamRejectsKeyAndRevocationFailures</code>	None for the modeled HTTP key and revocation failure modes
LRTT05	Completed	<code>TestAGTPObserveIdentityRedTeamRejectsAttestationBinderMismatch</code>	None for binder mismatch comparison
LRTT06	Completed	<code>TestVerifySessionIdentityJWTEnvelopeRedTeamRejectsSubstitution</code>	Runtime client configuration remains two-token JWT/JWS-wired unless callers use the envelope verifier directly
LRTT07	Completed	<code>TestAGTPObserveIdentityRedTeamRejectsVerifiedGrantCacheMisuse</code>	None for the modeled verified-grant cache misuse path
LRTT08	Superseded by LRTT15 gateway work	SSOT separates gateway mode from the direct-Agent trust model; <code>docs/gateway-route-d-profile.md</code> now defines the companion profile	Full gateway-routed runtime harness remains future work
LRTT09	Completed locally	<code>TestValidateResponseCachePolicyRedTeamRejectsCallerDependentPublicCache; TestValidateResponseCachePolicyRedTeamPartitionsPrivateCache</code>	This is a dependency-free policy and cache-key harness, not a live AGTP daemon response-cache implementation
LRTT10	Not implemented	Tracked from the evaluation matrix	Real network relay with live endpoints and an active relay
LRTT11	Not implemented	Tracked from the evaluation matrix	Hardware-generated borrowed attestation replay
LRTT12	Completed for the dependency-free loopback harness	<code>TestVerifySessionIdentityJWTLiveRedTeamRejectsNetworkRelayAcrossEndpoints</code>	Uses two live local TLS endpoints and relayed profile material; it is not a full malicious forwarding proxy
LRTT13	Completed for HTTP/2	<code>TestVerifySessionIdentityJWTLiveRedTeamHTTP2ConnectionReuse</code>	gRPC connection-pooling coverage remains future work

ID	Status	Completion evidence	Boundary
LRTT14	Completed for local TLS resumption and pre-binding rejection	<code>TestVerifySessionIdentityJWTLiveRedTeamRejectsTLSResumptionReplayAndPreBinding</code>	Go's standard TLS stack does not expose a 0-RTT early-data API, so real 0-RTT transport coverage remains future work if such a stack is introduced
LRTT15a	Completed for profile text	<code>docs/gateway-routed-profile.md</code> fixes the Gateway Route Assertion claim set, signer, audience, expiry, replay key, canonicalization, and final-Agent relationship	Gateway route-confusion runtime harness remains future work
LRTT15b	Completed for profile text and local policy gate	<code>docs/gateway-routed-profile.md</code> ; <code>TestValidateAcceptsRouteAssertionWithAgentHolderProof</code> ; <code>TestValidateRejectsMissingRequiredAgentHolderProof</code>	Wire-token parsing for route assertions remains future work
LRTT15c	Completed for local red-team coverage	<code>TestValidateRejectsPolicyBoundDiversion</code> ; <code>TestValidateRejectsRouteAssertionReplay</code>	Full gateway-routed network harness remains future work
LRTT16	Completed for deterministic corpus tests	<code>TestVerifySessionIdentityJWTRedTeamRejectsMalformedCorpus</code> ; <code>TestVerifySessionIdentityCWTRedTeamRejectsMalformedCorpus</code>	Long-running Go fuzz jobs remain future work
LRTT17	Completed for deterministic invariant matrix	<code>TestVerifySessionIdentityJWTInvariantMatrix</code>	Randomized property generation remains future work

Completed Changes

- Consolidated the profile SSOT into `docs/SSOT.md`.
- Added the AGTP security-profile feedback list in `docs/agtp-security-profile-feedback.md`.
- Added JWT/JWS single-envelope verification and substitution red-team tests.
- Added CWT/COSE Identity Grant and Session Binding Statement verification with COSE profile red-team tests.
- Added local multi-process replay-race coverage through a shared SETNX-style replay service.
- Added local loopback relay and HTTP/2 connection-reuse live red-team harnesses for session-bound JWT/JWS identity.
- Added local TLS 1.3 resumption coverage and a pre-binding rejection case for the JWT/JWS acceptance gate.
- Added deterministic JWT/JWS and CWT/COSE malformed-token corpus tests.

- Fixed the Gateway Route Assertion claim map in the gateway-routed profile.
- Added Gateway Route Assertion holder-of-key proof rules and a local `pkg/agtp/gatewayroute` policy gate for route-bound identity.
- Added deterministic acceptance-invariant coverage for grant, binding, session, replay, and local policy linkage.
- Added key and revocation failure-mode coverage for stale JWKS, timeouts, HTTP 500, key rotation overlap, disabled keys, and revoked grant IDs.
- Added response-cache policy coverage for caller-dependent shared-cache leakage and private cache partitioning.
- Added the dedicated `.github/workflows/security-red-team.yaml` workflow.

Residual Boundaries

These are not blockers for the completed branch; they are profile or deployment boundaries that need separate work if the project chooses to support them.

- Hardware-generated confidential-VM attestation evidence is not produced inside GitHub Actions.
- CWT/COSE verification exists in `pkg/agtp`, but client configuration is still wired for the JWT/JWS runtime path.
- Replay race coverage uses a local HTTP SETNX-style service, not a real multi-node Redis or Valkey deployment.
- Gateway-routed deployments now have a fixed route-assertion claim map, holder-of-key proof rules, a local policy gate, and JWT/CWT route-assertion adapters. Runtime client/server wiring and a full gateway network harness remain separate work.
- HTTP/2 connection reuse is covered locally; gRPC connection-pooling coverage remains separate work.
- TLS resumption is covered locally; real 0-RTT early-data transport coverage remains separate work because this harness uses Go's standard TLS stack.
- JWT/JWS and CWT/COSE malformed corpus tests are deterministic local tests, not long-running fuzz jobs.
- LRTT17 is a deterministic invariant matrix, not a randomized property-test generator.